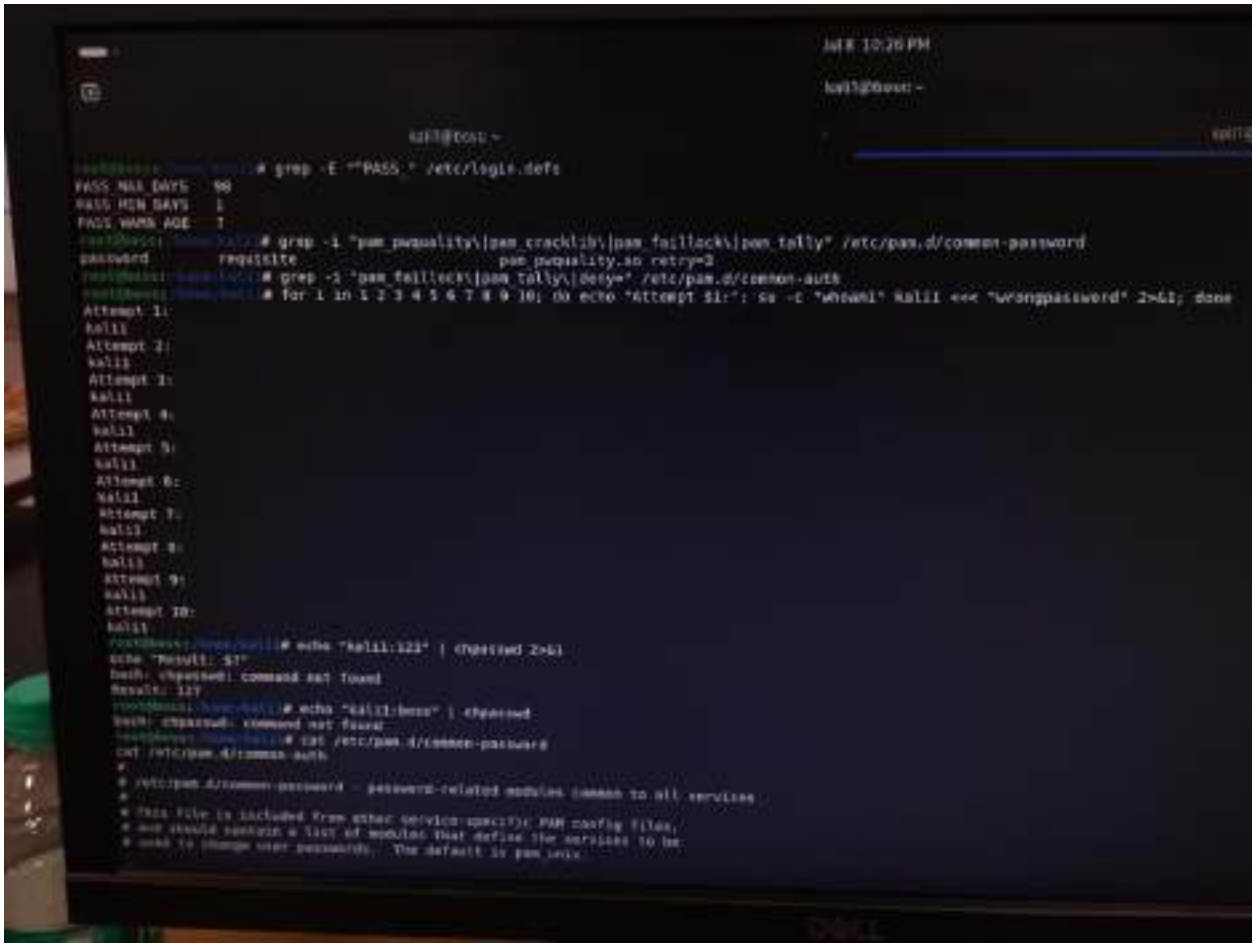
Authentication, Access Control, and Privilege Management

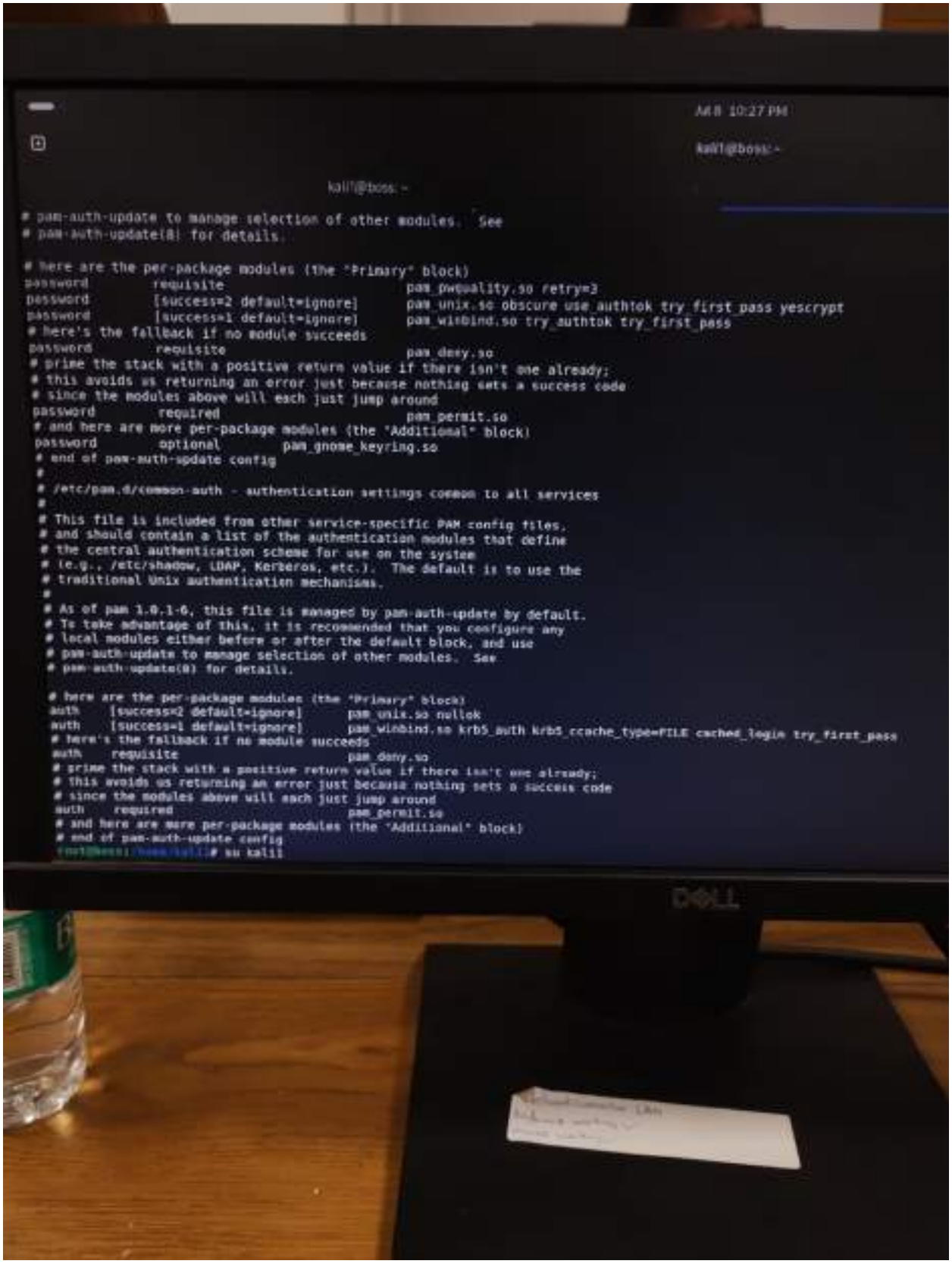
Topic - Weak password policy

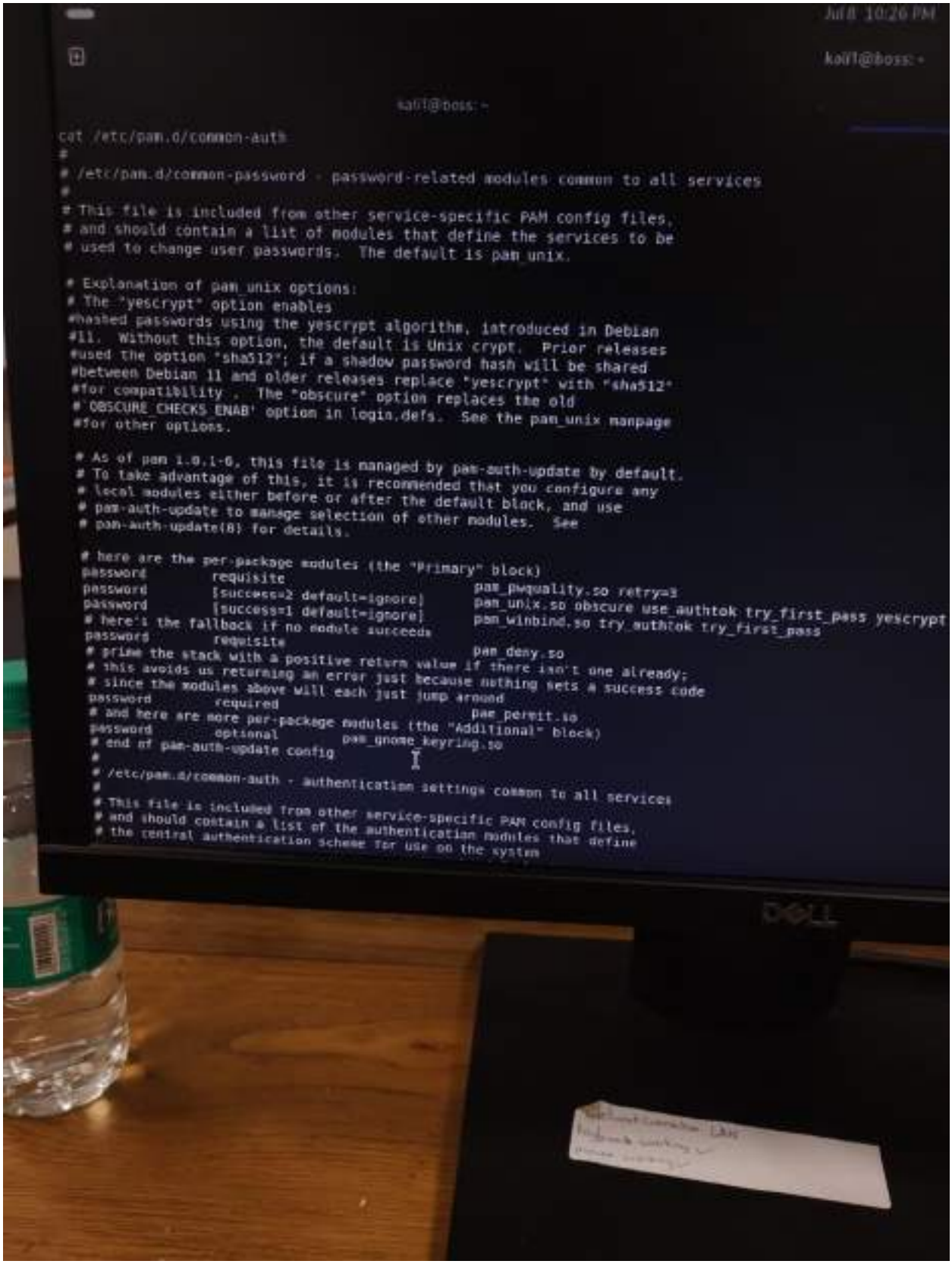
Step 1 : show the passwd ageing policy

Step 2 shows the pam passwd quality settings
Step3 There is no account logout

Ultimate brute force available




Jul 8 10:27 PM
kali1@boss: ~
kali1@boss: ~
pam-auth-update to manage selection of other modules. See
pam-auth-update(8) for details.
here are the per-package modules (the "Primary" block)
password requisite pam_pwquality.so retry=3
password [success=2 default=ignore] pam_unix.so obscure use_authtok try_first_pass yescrypt
password [success=1 default=ignore] pam_winbind.so try_authtok try_first_pass
here's the fallback if no module succeeds
password requisite pam_deny.so
prime the stack with a positive return value if there isn't one already;
this avoids us returning an error just because nothing sets a success code
since the modules above will each just jump around
password required pam_permit.so
and here are more per-package modules (the "Additional" block)
password optional pam_gnome_keyring.so
end of pam-auth-update config
#
/etc/pam.d/common-auth - authentication settings common to all services
#
This file is included from other service-specific PAM config files,
and should contain a list of the authentication modules that define
the central authentication scheme for use on the system
(e.g., /etc/shadow, LDAP, Kerberos, etc.). The default is to use the
traditional Unix authentication mechanisms.
#
As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
To take advantage of this, it is recommended that you configure any
local modules either before or after the default block, and use
pam-auth-update to manage selection of other modules. See
pam-auth-update(8) for details.
here are the per-package modules (the "Primary" block)
auth [success=2 default=ignore] pam_unix.so nullok
auth [success=1 default=ignore] pam_winbind.so krb5_auth krb5_ccache_type=FILE cached_login try_first_pass
here's the fallback if no module succeeds
auth requisite pam_deny.so
prime the stack with a positive return value if there isn't one already;
this avoids us returning an error just because nothing sets a success code
since the modules above will each just jump around
auth required pam_permit.so
and here are more per-package modules (the "Additional" block)
end of pam-auth-update config
su kali1
DELL


kali@boss: ~
cat /etc/pam.d/common-auth
#
/etc/pam.d/common-password - password-related modules common to all services
#
This file is included from other service-specific PAM config files,
and should contain a list of modules that define the services to be
used to change user passwords. The default is pam_unix.
Explanation of pam_unix options:
The "yescrypt" option enables
#hashed passwords using the yescrypt algorithm, introduced in Debian
#11. Without this option, the default is Unix crypt. Prior releases
#used the option "sha512"; if a shadow password hash will be shared
#between Debian 11 and older releases replace "yescrypt" with "sha512"
#for compatibility . The "obscure" option replaces the old
OBSCURE_CHECKS_ENAB' option in login.defs. See the pam_unix manpage
#for other options.
As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
To take advantage of this, it is recommended that you configure any
local modules either before or after the default block, and use
pam-auth-update to manage selection of other modules. See
pam-auth-update(8) for details.
here are the per-package modules (the "Primary" block)
password   requisite   pam_pwquality.so retry=3
password   [success=2 default=ignore]   pam_unix.so obscure use_authtok try_first_pass yescrypt
password   [success=1 default=ignore]   pam_winbind.so try_authtok try_first_pass
here's the fallback if no module succeeds
password   requisite   pam_deny.so
prime the stack with a positive return value if there isn't one already;
this avoids us returning an error just because nothing sets a success code
since the modules above will each just jump around
password   required   pam_permit.so
and here are more per-package modules (the "Additional" block)
password   optional   pam_gnome_keyring.so
end of pam-auth-update config
#
/etc/pam.d/common-auth - authentication settings common to all services
#
This file is included from other service-specific PAM config files,
and should contain a list of the authentication modules that define
the central authentication scheme for use on the system